Enterprise Infrastructure Architecture

ICT Infrastructure Case Study – Week 2: Architectural Foundation

Case Study

Bas Smit

Fontys University of Applied Sciences

Fontys
University of Applied Sciences

Contents

1 Introduction **1**
1.1 Assumptions and Scope . . . 1

2 Enterprise Context **2**
2.1 Organisation Overview . . . 2
2.2 Locations . . . 2
2.3 Organisational Structure . . . 2
2.4 Core Business Processes . . . 2
2.5 Business Criticality and Risk Profile . . . 3
2.6 Key Stakeholders and Their Interests . . . 3
2.7 Customer Load and Capacity Assumptions . . . 3
2.8 Summary of Assumptions . . . 3

3 Architecture Method **5**
3.1 TOGAF and the Architecture Development Method . . . 5
3.2 ArchiMate as Modelling Language . . . 5
3.3 How the Method Influenced This Work . . . 6

4 Enterprise Infrastructure Architecture **7**
4.1 Architectural Principles . . . 7
4.2 Network Segmentation . . . 7
4.3 Site: Eindhoven (Primary) . . . 7
4.3.1 Perimeter and DMZ . . . 8
4.3.2 Application Server Clusters . . . 8
4.3.3 Message Broker: RabbitMQ . . . 8
4.3.4 Backend: Database Layer . . . 9
4.3.5 Management Segment . . . 9
4.4 Site: Groningen (Secondary) . . . 9
4.5 Inter-Site Connectivity . . . 9
4.6 ArchiMate Technology Layer View . . . 9
4.7 Architectural Decisions and Trade-offs . . . 9
4.7.1 On-premises vs. Cloud . . . 9
4.7.2 RabbitMQ vs. Kafka . . . 11
4.7.3 PostgreSQL vs. a Single Database Type . . . 11
4.7.4 Groningen WMS Autonomy . . . 11

5 Requirements Analysis **12**
5.1 Management Requirements . . . 12
5.2 User Requirements . . . 12
5.3 Functional Requirements . . . 12
5.4 Non-Functional Requirements . . . 13
5.4.1 Availability . . . 13
5.4.2 Performance . . . 13
5.4.3 Security . . . 13
5.4.4 Scalability and Capacity . . . 13

6 Assignments **14**
6.1 Assignment 2 – Business Service to Technical Service Mapping . . . 14
6.1.1 Service Mapping . . . 14
6.1.2 Dependency Analysis . . . 15
6.1.3 Dashboard Design . . . 15

6.2 Assignment 3 – Status and Performance Monitoring Solution 15
6.2.1 Scope and Objectives 15
6.2.2 Architecture 16
6.2.3 Alert Thresholds 17
6.2.4 Groningen Site Monitoring 17
6.2.5 SLA Reporting 17
6.3 Assignment 7 – Logging and Forensic Data Collection 17
6.3.1 Objectives 17
6.3.2 Log Sources 18
6.3.3 Centralised Log Architecture 18
6.3.4 Retention Policy 19
6.3.5 Forensic Readiness 19
6.3.6 Information Flow 19
6.3.7 GDPR Considerations 20

1 Introduction

This document presents the architectural foundation for the ICT Infrastructure Case Study, prepared in the role of Enterprise Infrastructure Architect. The approach is grounded in TOGAF as the enterprise architecture framework and ArchiMate as the modelling language, meaning that all infrastructure and monitoring decisions are derived from and traced back to a defined business context, stakeholder needs, and identified risks. No implementation or system administration tasks are within scope — this document focuses on research, design, and architectural advice.

1.1. Assumptions and Scope

All infrastructure and monitoring designs are based on the enterprise context established in Chapter 2. Where assumptions were made, they are explicitly stated. The combined network and functional architecture diagram required by Assignment 1 is embedded in Chapter 4, Section 4.6, using ArchiMate notation rendered with TikZ.

2

Enterprise Context

This chapter establishes the organisational foundation from which all architectural decisions in this document are derived. Following TOGAF ADM Phase A, the organisation, its locations, workforce, core business processes, stakeholders, and risk profile are defined before any technical design begins.

2.1. Organisation Overview

LogiFlux B.V. is a fictitious Dutch regional wholesale distribution company operating in the Fast-Moving Consumer Goods (FMCG) sector. Incorporated as a private limited company (B.V.) in the Netherlands in 2009, LogiFlux acts as an intermediary between product suppliers and retail customers, managing the full supply chain from goods intake and warehousing through to order fulfilment and last-mile delivery. The company generates an estimated annual revenue of €42 million and serves retail chains, independent supermarkets, and hospitality businesses across the Netherlands.

2.2. Locations

LogiFlux operates from two permanent physical sites. The primary site in Eindhoven houses the executive team, IT department, finance, HR, customer service, and the main warehouse and distribution operations. A secondary distribution centre in Groningen serves customers in the northern Netherlands and operates under a regional operations manager reporting to Eindhoven. The two sites are approximately 220 km apart and are connected via a leased MPLS WAN link with a redundant internet-based VPN failover path.

2.3. Organisational Structure

LogiFlux employs approximately 200 staff. The largest group consists of 120 employees in distribution centre roles covering warehousing, logistics, and driving, split roughly 70 in Eindhoven and 50 in Groningen. Customer service (24 staff) and administration covering finance and HR (12 staff) are centralised in Eindhoven, alongside the IT department (10 staff) and senior management (8 staff). Maintenance and support roles (26 staff) operate across both sites. The IT team's size — ten people responsible for the entire infrastructure — is a significant constraint that drives the requirements for manageability, automation, and centralised monitoring.

2.4. Core Business Processes

The following core business processes drive all infrastructure and monitoring requirements:

1. **Customer Order Management** — Retail customers place orders via the customer portal (web-based) or by telephone via customer service representatives. Orders are processed, validated against inventory and scheduled for fulfilment.
2. **Goods Storage and Distribution** — Warehouse staff receive, store and pick goods across both

distribution centres. The system manages inventory levels, triggers replenishment and coordinates outbound logistics.

3. **Financial Administration and Accounting** — The finance department processes invoices, manages accounts payable and receivable, and produces financial reporting. This process is subject to Dutch regulatory requirements (Belastingdienst, GDPR).
4. **Salary Administration and Personnel Registration** — HR manages contracts, payroll, attendance records and personnel data. This is a high-sensitivity process due to the personal and financial data involved.

2.5. Business Criticality and Risk Profile

LogiFlux operates in a time-sensitive distribution environment, and the criticality of its business processes is reflected directly in how infrastructure availability requirements are set. Customer Order Management and Goods Storage and Distribution are both high-criticality processes: downtime in either results in lost orders, missed SLAs, contractual penalties, or an operational standstill. Financial Administration and HR carry medium criticality — outages are disruptive and may trigger regulatory issues, but their immediate revenue impact is lower than a halt in order processing.

Several risk factors compound this profile. Seasonal promotional periods can cause customer transaction volumes to spike from a daily average of around 1,200 to as many as 10,000 — an 8:1 ratio — meaning infrastructure must absorb peak load without manual intervention. The Groningen site has limited local IT staff, making remote management and monitoring non-negotiable rather than optional. Financial records, payroll data, and customer purchase histories are all subject to GDPR, adding legal obligation to the security requirements. Integration with supplier systems via EDI creates external dependency risks, and LogiFlux's profile as a mid-size distribution company with financial transaction exposure makes it a realistic target for ransomware and business email compromise attacks.

2.6. Key Stakeholders and Their Interests

The architecture must serve a range of stakeholders with different concerns, and these concerns ultimately translate into concrete requirements. The CEO and Board are primarily interested in business continuity, cost efficiency, regulatory compliance, and reputational risk. The Operations Director's focus is the uninterrupted availability of order and warehouse systems during operational hours, while the IT Director cares about infrastructure reliability, security posture, manageability, and scalability. The Finance Manager requires data integrity in accounting systems, complete audit trails, and regulatory compliance; the HR Manager prioritises GDPR compliance, payroll accuracy, and role-restricted access to personnel data.

Closer to daily operations, the Customer Service team needs reliable access to the order system and fast issue resolution. Distribution staff at both sites depend on the warehouse management system remaining available throughout their shifts. Retail customers expect order accuracy, portal availability, on-time delivery, and confidence that their data is handled appropriately. These stakeholder concerns are not independent — they converge on a shared need for infrastructure that is highly available, secure, observable, and traceable to individual identities.

2.7. Customer Load and Capacity Assumptions

Average daily customer transaction volume is approximately 1,200, rising to up to 10,000 during seasonal peaks — a peak-to-average ratio of roughly 8:1. Infrastructure must therefore be sized for burst capacity rather than steady-state demand, while avoiding permanent over-provisioning. Warehouse operations run Monday to Friday from 07:00 to 18:00; the customer portal must be available around the clock. Internal user concurrency peaks during morning shift handover between 07:00 and 09:00, with a maximum of approximately 200 concurrent users.

2.8. Summary of Assumptions

The following assumptions underpin this entire document:

1. LogiFlux B.V. is a fictional organisation. Any resemblance to real companies is coincidental.
2. Both physical sites are in the Netherlands; all regulations referenced are Dutch/EU.
3. The IT department (10 staff) is responsible for all infrastructure, with no dedicated security operations centre (SOC). Security monitoring is managed by the IT team.
4. No existing enterprise architecture documentation is assumed to exist; this document represents a greenfield design.
5. Cloud services may be used where cost-effective and appropriate; on-premises infrastructure is preferred for sensitive data.
6. The leased MPLS link between sites provides the primary inter-site connectivity; an internet-based VPN acts as failover.

3

Architecture Method

This chapter explains the methodological choices that structure this entire document. TOGAF and ArchiMate are not cited as decorative references — they actively determine how the analysis is conducted, how decisions are recorded, and how diagrams are constructed.

3.1. TOGAF and the Architecture Development Method

TOGAF's core process is the **Architecture Development Method (ADM)**, an iterative cycle of phases for developing and maintaining enterprise architecture. This case study directly applies five ADM phases. The Preliminary phase establishes the architectural approach, scope, and principles, including the choice of TOGAF and ArchiMate and the reasoning behind it. Phase A (Architecture Vision) corresponds to the enterprise context chapter: defining the organisation, stakeholders, business goals, and risk profile before any technical design begins. Phase B (Business Architecture) drives the requirements analysis in Chapter 5, ensuring every requirement is attributed to a stakeholder, business process, or identified risk. Phases C and D (Information Systems Architecture and Technology Architecture) together underpin the infrastructure design in Chapter 4, mapping business services to application and data components and then to the physical and virtual infrastructure. Phase E (Opportunities and Solutions) informs the monitoring design in the assignments chapter, identifying where monitoring solutions address gaps exposed during the architecture phases.

TOGAF's principle of **traceability** is applied throughout: every infrastructure component and monitoring decision is traceable back to a business requirement, stakeholder concern, or identified risk defined in the enterprise context.

3.2. ArchiMate as Modelling Language

ArchiMate is an open modelling language standardised by The Open Group, designed to describe, analyse and visualise enterprise architectures across multiple domains. It is used in this document to produce architecture diagrams that are consistent, unambiguous and layered.

ArchiMate organises elements across three layers. The **Business Layer** represents processes, roles, functions, and services as experienced by stakeholders — Customer Order Management and Salary Administration are examples at this layer. The **Application Layer** represents the software applications and services that support those business processes, such as the order management system, IAM/SSO, and ERP. The **Technology Layer** represents the physical and virtual infrastructure that hosts applications: server clusters, VLANs, firewalls, storage, and WAN links.

Relationships between elements (such as *realisation*, *serving*, *assignment* and *composition*) are used to make dependencies and interactions explicit. This prevents the common pitfall of designing infrastructure in isolation from the business functions it must support.

3.3. How the Method Influenced This Work

The choice of TOGAF and ArchiMate had concrete effects on the structure and content of this document. Following ADM Phase A, the enterprise context was defined before any technical design began, so infrastructure choices are consequences of business needs rather than the reverse. All architecture diagrams use ArchiMate notation to clearly separate business, application, and technology concerns, keeping dependencies visible and reviewable by stakeholders at every level. Requirements are attributed to their stakeholder or process source rather than being a generic technical wish-list, and every significant infrastructure choice is accompanied by a justification and trade-off discussion, in line with TOGAF's emphasis on documented architectural decisions with explicit rationale.

4

Enterprise Infrastructure Architecture

This chapter presents the enterprise infrastructure architecture for LogiFlux B.V., covering network segmentation, application topology, inter-site connectivity, and the key design decisions that shaped these choices. All components are traceable to the business processes and stakeholder requirements established in Chapter 2.

4.1. Architectural Principles

Six principles govern all infrastructure design decisions for LogiFlux B.V., derived from the enterprise context and TOGAF's concept of architecture principles as guiding constraints.

Separation of concerns divides the infrastructure into clearly isolated network segments — DMZ, Application, Database, Management, and Client. No segment communicates with another unless explicitly required and controlled by a firewall rule. This supports **defence in depth**: external traffic passes through a perimeter firewall before reaching the DMZ, and internal application traffic passes through an additional internal firewall before reaching application servers.

Least privilege access means that application servers are reachable only through the web front-end, and database servers are reachable only by application servers. No direct external access to backend systems is permitted. **High availability** ensures that all business-critical components — web cluster, application clusters, message broker, database clusters — are clustered to eliminate single points of failure, with both sites independently operational.

Scalability for peak loads is addressed by auto-provisioning the front-end web cluster to handle the 8:1 peak-to-average customer load ratio, supported by a NoSQL database layer capable of high-throughput read handling during peak periods. Finally, **traceability** requires that every infrastructure component maps directly to one or more business processes defined in the enterprise context, ensuring no component exists without a justified business need.

4.2. Network Segmentation

The infrastructure is segmented using VLANs. Each VLAN corresponds to a logical security zone. Inter-VLAN traffic is routed through firewall policies, not open routing. The VLAN design is consistent across both sites, with separate IP ranges per site to avoid conflicts.

IP addressing follows a consistent scheme: Eindhoven uses the `10.0.x.0/24` range (where `x` is the VLAN ID), and Groningen uses `10.1.x.0/24`. Inter-site WAN connectivity uses `10.10.0.0/30`. The IAM server resides in the DMZ at a static address accessible from all VLANs.

4.3. Site: Eindhoven (Primary)

Eindhoven is the primary site hosting all core application workloads. It serves both local staff and all external customers.

VLAN ID	Name	Purpose and Key Components
10	DMZ	Public-facing services: load balancer, auto-provisioned web cluster, SSL/TLS termination. All inbound internet traffic enters here.
20	Application	Isolated application server clusters (Order System, Accounting, HR/Payroll, Warehouse). Accessible only via Internal Firewall from DMZ.
30	Message Broker	RabbitMQ cluster, isolated from both App and DB VLANs. Accessed by App clusters via broker API only.
40	Database	PostgreSQL (relational) and MongoDB (NoSQL) clusters. No direct access from DMZ or clients.
50	Management	Monitoring server, jump host, configuration management. Administrative access only via IAM-authenticated session.
60	Client	Staff Windows endpoints. Outbound internet access via proxy; inbound access to applications via web browser through DMZ.

Table 4.1: VLAN segmentation design for LogiFlux B.V.

4.3.1. Perimeter and DMZ

Inbound internet traffic (customer portal, staff remote access) terminates at the perimeter firewall. All allowed traffic is forwarded to the load balancer in the DMZ, which distributes requests across the auto-provisioned web cluster. The web cluster handles HTTP/HTTPS and communicates only with the application layer via the internal firewall.

The **Identity and Access Management (IAM)** server is co-located in the DMZ at a static address. It provides Single Sign-On (SSO) and role-based access control for all applications. Users authenticate once against the IAM before being granted access to any application, regardless of which cluster handles the request.

4.3.2. Application Server Clusters

Four isolated application clusters run in the Application VLAN. Each cluster is independently deployable and contains a mix of Windows and Linux nodes depending on the application stack's requirements.

Four isolated application clusters run in the Application VLAN, each independently deployable with a mix of Windows and Linux nodes suited to the application's requirements. The **Customer Order System** cluster runs on Linux and handles customer order submission, validation, status tracking, and the public customer portal; it carries the highest traffic volume and is the primary consumer of the MongoDB layer for read-heavy requests. The **Accounting** cluster runs on Windows, processing invoices, accounts payable and receivable, and financial reporting — strict audit logging is required, and it writes exclusively to the relational PostgreSQL database. The **HR/Salary Administration** cluster also runs on Windows, managing personnel records, payroll, contracts, and attendance data; access is role-restricted via the IAM due to the high sensitivity of payroll data. Finally, the **Goods Storage and Distribution** cluster runs on Linux, implementing the warehouse management system for inventory, pick lists, and inbound/outbound logistics coordination, and publishes fulfilment trigger events to RabbitMQ.

4.3.3. Message Broker: RabbitMQ

A RabbitMQ cluster resides in the dedicated Message Broker VLAN, isolated from both the Application and Database VLANs. It provides asynchronous event-driven communication between application clusters, decoupling producers from consumers and improving resilience during peak load.

Three primary message flows traverse the broker. When a customer order is confirmed, the Order System publishes an event to a queue consumed by the Warehouse cluster, decoupling the order creation flow from warehouse picking and preventing order spikes from directly impacting warehouse throughput. Confirmed orders also trigger invoice creation events consumed asynchronously by the Accounting cluster, keeping financial processing out of the synchronous order submission path. The third flow handles Groningen inventory synchronisation: inventory updates from the Groningen WMS node are published to a queue and replicated to the Eindhoven Warehouse cluster, ensuring consistent stock

levels across sites even during brief WAN interruptions, with messages queuing locally and delivering on reconnect.

4.3.4. Backend: Database Layer

The database layer runs in a dedicated DB VLAN with no direct external access. Two clustered database systems are provided:

PostgreSQL serves the Accounting, HR/Payroll, and Order System clusters for transactional, structured data requiring ACID compliance. A hot-standby replica in Eindhoven provides automated failover, and a read replica is deployed in Groningen for local WMS queries. **MongoDB** serves the Customer Order System for high-throughput, read-heavy customer request handling; its flexible document model accommodates variable order structures and scales horizontally to absorb peak loads of up to 10,000 transactions per day.

4.3.5. Management Segment

The Management VLAN contains a monitoring server (collecting metrics, logs and health data from all infrastructure components) and a jump host. All administrative access to servers is routed through the jump host, which enforces IAM authentication and session logging. Direct SSH or RDP access from the Client VLAN to production servers is not permitted.

4.4. Site: Groningen (Secondary)

Groningen is a secondary distribution site with limited local IT staff. Its infrastructure is designed for operational independence in the event of a WAN failure, while staying synchronised with Eindhoven under normal conditions.

A perimeter firewall provides site-level security and manages the MPLS/VPN WAN connection. The Client VLAN hosts approximately 50 Windows endpoints used by warehouse and distribution staff; applications are accessed via browser through the Eindhoven-hosted portal, with no local application servers required for most functions. A local **WMS Node** can operate offline in read/write mode during a WAN outage using a local database cache, with changes queued and synchronised via RabbitMQ once the WAN link is restored. A **PostgreSQL read replica** of the Eindhoven cluster reduces WAN latency for WMS read queries and provides a local fallback for inventory queries during WAN disruption.

4.5. Inter-Site Connectivity

The primary inter-site link is a leased MPLS connection providing a guaranteed bandwidth of at least 100 Mbit/s with low latency; it carries all application traffic between sites, including database replication and RabbitMQ message sync. An internet-based IPSec VPN serves as automatic failover if the MPLS link fails, providing a minimum of 20 Mbit/s to ensure continuity for critical WMS and database replication traffic.

All inter-site traffic is encrypted at the network layer regardless of whether MPLS or VPN is in use.

4.6. ArchiMate Technology Layer View

The diagram below presents the technology layer view of the LogiFlux B.V. enterprise infrastructure using ArchiMate notation. Element types are annotated in italic above each element name. Colours indicate the ArchiMate element category per the legend.

4.7. Architectural Decisions and Trade-offs

4.7.1. On-premises vs. Cloud

Sensitive data workloads (HR/Payroll, Accounting) are hosted on-premises to maintain full control over GDPR-governed data and avoid dependency on third-party cloud providers. The Customer Order System and MongoDB layer are candidates for future cloud migration if scaling demands exceed on-premises capacity, particularly given the 8:1 peak-to-average ratio.

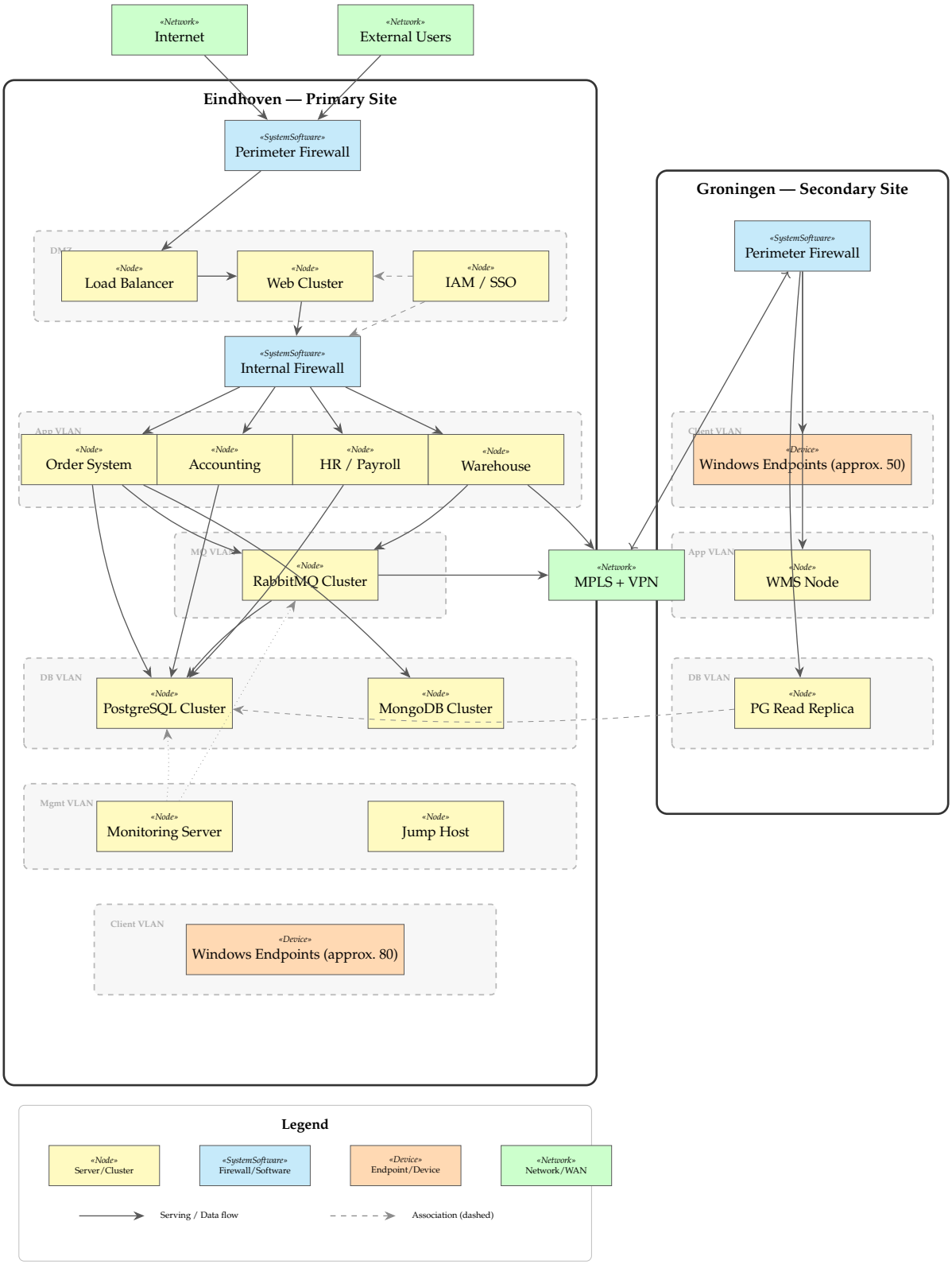

Figure 4.1: ArchiMate Technology Layer View — LogiFlux B.V. Enterprise Infrastructure

4.7.2. RabbitMQ vs. Kafka

RabbitMQ was selected over Apache Kafka for the message broker layer. At LogiFlux's current scale (order of thousands of daily transactions), RabbitMQ's lower operational overhead and simpler queue management model are better suited to a 10-person IT team. Kafka's log-based architecture offers better throughput at much larger scale but introduces significant operational complexity that is disproportionate to LogiFlux's needs.

4.7.3. PostgreSQL vs. a Single Database Type

A deliberate decision was made to deploy both a relational (PostgreSQL) and a NoSQL (MongoDB) database rather than relying on a single database type. The relational model is required for transactional integrity in financial and HR processes. The NoSQL model is required for the high-throughput, read-heavy customer portal workload. Forcing all workloads into a single database type would require either sacrificing ACID compliance for financial data or accepting poor performance on the customer-facing side.

4.7.4. Groningen WMS Autonomy

The Groningen WMS node is designed to continue operating in degraded mode during a WAN outage by using a local PostgreSQL read replica and an offline write queue. This design choice accepts the risk of brief data inconsistency (resolved on WAN recovery via RabbitMQ replay) in exchange for operational continuity at the distribution site. A full WAN outage would otherwise halt all warehouse operations at Groningen.

5

Requirements Analysis

This chapter applies TOGAF ADM Phase B (Business Architecture) to derive requirements from the enterprise context, stakeholder concerns and identified risks defined in Chapter 2. Requirements are not generated from technical preferences; each requirement is explicitly traced to a source.

5.1. Management Requirements

Management requirements address how the IT team and senior leadership observe and control the infrastructure. The IT Director requires a single monitoring dashboard aggregating status, performance, and alerts from both sites (**MR-01**), with automated alerting notifying on-call IT staff within two minutes of a critical component failure (**MR-02**). To serve non-technical stakeholders, the Operations Director requires read-only, role-restricted operational dashboards for the Order System and Warehouse that can be used without IT involvement (**MR-03**). The CEO and Board require automatically generated monthly availability reports for the Customer Order System and customer portal to support SLA validation (**MR-04**). All administrative access to production servers must be logged and traceable to an individual IAM identity (**MR-05**), and infrastructure capacity data — CPU, memory, and storage trends — must be retained for a minimum of 13 months to support annual capacity planning cycles (**MR-06**).

5.2. User Requirements

User requirements express what different groups of people need the infrastructure to do for them. The Customer Service team requires the order portal to be accessible 24/7, with a status page publishing degraded-mode notifications when planned maintenance is in progress (**UR-01**). Distribution staff at both sites require the Warehouse Management System to remain operational during a WAN outage, necessitating an offline mode at Groningen (**UR-02**). The Finance Manager requires a complete, immutable audit trail of all financial transactions accessible to authorised Finance staff for at least seven years, as required by Dutch fiscal law (**UR-03**). The HR Manager requires role-restricted access to the HR/Payroll system such that no IT staff member can access payroll data without explicit HR Manager authorisation (**UR-04**). IT staff require a jump host with session recording as the sole path to production servers, enabling post-incident forensic review of all administrative sessions (**UR-05**). Finally, retail customers require that the portal respond within two seconds for standard order operations under normal load conditions (**UR-06**).

5.3. Functional Requirements

Functional requirements define specific system behaviours that the infrastructure must support. The Order System must handle at least 10,000 customer transactions per day during seasonal peaks without service degradation (**FR-01**). Inventory events from both sites must be synchronised via the RabbitMQ message broker, with guaranteed delivery and a replay capability on WAN recovery (**FR-02**). Invoice creation events must be published asynchronously by the Order System so that accounting processing does not block the order submission path (**FR-03**). Payroll data must be encrypted at rest and in

transit, with all access logged at the application level including user identity, timestamp, and action (**FR-04**). All application access must require SSO authentication through the IAM, and direct database or server access that bypasses the IAM is not permitted (**FR-05**). Metrics, logs, and health data from all infrastructure components must be collected centrally in the Management VLAN (**FR-06**). Finally, the Groningen WMS node must queue write operations locally and replay them to the central cluster when the WAN link is restored (**FR-07**).

5.4. Non-Functional Requirements

5.4.1. Availability

Availability targets are set per system, reflecting the criticality analysis from Chapter 2. The Customer Portal (**NFR-AV-01**) and Order System (**NFR-AV-02**) both carry a 99.9% target, permitting no more than 8.7 hours of downtime per year; this reflects their status as revenue-critical, customer-facing systems. The IAM/SSO server (**NFR-AV-06**) matches this 99.9% target because a single IAM failure would prevent access to all applications simultaneously. The Warehouse/WMS (**NFR-AV-03**) is set at 99.5% measured during operational hours (07:00–18:00), as brief degraded-mode operation outside those hours is acceptable. The Accounting system (**NFR-AV-04**) and HR/Payroll system (**NFR-AV-05**) both target 99.0%, reflecting their business-hours-only usage patterns and the fact that brief outages outside office hours do not materially affect operations.

5.4.2. Performance

Customer portal page load time must not exceed 2 seconds under normal load of 1,200 transactions per day (**NFR-PERF-01**, derived from UR-06) and must remain within 5 seconds under peak load of 10,000 transactions per day (**NFR-PERF-02**); the web cluster's auto-scaling capability must absorb the 8:1 peak-to-average ratio without manual intervention. RabbitMQ message processing latency must remain below 500 ms under normal load (**NFR-PERF-03**, derived from FR-03), and 95% of PostgreSQL queries must complete within 200 ms under normal conditions (**NFR-PERF-04**, derived from FR-01). WAN failover from the MPLS link to the IPSec VPN must complete within 60 seconds without manual intervention (**NFR-PERF-05**).

5.4.3. Security

All data in transit between VLANs, sites, and external parties must be encrypted using TLS 1.2 as a minimum with TLS 1.3 preferred (**NFR-SEC-01**, derived from GDPR obligations). Data at rest in the HR/Payroll and Accounting clusters must be encrypted using AES-256 or equivalent (**NFR-SEC-02**, derived from UR-04 and GDPR). Multi-factor authentication must be enforced for all IT staff, management, and Finance/HR roles via the IAM (**NFR-SEC-03**), and all firewall rule changes must be logged, version-controlled, and require dual approval from IT management (**NFR-SEC-04**, derived from MR-05). Security logs must be retained for a minimum of 12 months online and 36 months in cold storage (**NFR-SEC-05**), as required by GDPR Article 5(1)(e) and incident response readiness obligations.

5.4.4. Scalability and Capacity

The web cluster must auto-scale horizontally to absorb the 8:1 peak-to-average load ratio without manual intervention (**NFR-CAP-01**). MongoDB must support horizontal shard expansion to accommodate customer base growth of up to 300% without requiring an architectural redesign (**NFR-CAP-02**). Storage capacity for all systems must include a minimum 30% headroom above projected 12-month utilisation (**NFR-CAP-03**). Capacity metrics must trigger a planning review alert when any critical resource sustains utilisation above 70% of provisioned capacity for seven consecutive days (**NFR-CAP-04**).

6

Assignments

This chapter addresses four of the seven optional assignments. Assignment 1 (combined network and functional architecture diagram) has already been completed in Chapter 4, Section 4.6, using ArchiMate notation and TikZ. Assignment 2 maps business services to technical services and explains how this mapping could be represented in a monitoring dashboard. Assignment 3 designs a solution for status and performance monitoring of all servers. Assignment 7 designs a solution for logging and forensic data collection.

6.1. Assignment 2 – Business Service to Technical Service Mapping

6.1.1. Service Mapping

An enterprise monitoring strategy must not only observe infrastructure components in isolation but must express the health of infrastructure in terms that are meaningful to the business. This requires an explicit mapping between business services, as understood by stakeholders, and the technical services and components that realise them.

The **Customer Order Portal** is realised by the Order System Cluster and depends on the full depth of the Eindhoven stack: the Perimeter Firewall, Load Balancer, Web Cluster, IAM/SSO server, Internal Firewall, Order System Cluster itself, MongoDB Cluster, RabbitMQ Cluster, and PostgreSQL Cluster. Because it is customer-facing and revenue-critical, any failure in this chain has direct business impact.

Goods Storage and Distribution is delivered across both sites. It depends on the Internal Firewall, Warehouse Cluster, RabbitMQ Cluster, and PostgreSQL Cluster in Eindhoven, as well as the WAN link (MPLS/VPN), the Groningen Perimeter Firewall, the WMS Node in Groningen, and the PostgreSQL Read Replica in Groningen. The WAN link is therefore a shared dependency between this service and the inter-site replication it requires.

Financial Administration relies on the Accounting Cluster, which in turn depends on the Internal Firewall, PostgreSQL Cluster, and the RabbitMQ Cluster for invoice creation events arriving asynchronously from the Order System. **Salary and Personnel Administration** follows a simpler dependency chain: the Internal Firewall, HR/Payroll Cluster, and PostgreSQL Cluster, with no message broker dependency.

Identity and Access Management is realised by the IAM/SSO server, which sits behind the Perimeter Firewall and uses the PostgreSQL Cluster as its user store. Its position as a shared dependency for every other service makes it uniquely critical: a single IAM failure blocks access to all six business services simultaneously. **IT Operations and Management** is supported by the Monitoring Server and Jump Host in the Management VLAN, both of which require IAM/SSO authentication for administrative access.

6.1.2. Dependency Analysis

The mapping reveals two critical shared dependencies that affect multiple business services simultaneously:

1. **IAM / SSO Node:** A failure of the IAM/SSO node would render all six business services inaccessible, as every application requires authentication. This justifies its NFR-AV-06 availability target of 99.9% and the recommendation to deploy it as a clustered pair.
2. **PostgreSQL Cluster:** Four of the six business services depend on PostgreSQL. A total PostgreSQL failure would halt financial administration, HR/payroll, IAM authentication and the relational component of order processing. The hot-standby replica in Eindhoven and the automatic failover mechanism (via a connection pooler such as PgBouncer with health-check failover) are therefore non-negotiable.

6.1.3. Dashboard Design

Design Principles

The monitoring dashboard is shaped by three principles drawn from the stakeholder analysis. The primary view must present service health in business terms — "Customer Order Portal: Operational" rather than server metrics — so that stakeholders without IT backgrounds, such as the Operations Director and CEO, can interpret it immediately. Role-based access then ensures that different stakeholders see the appropriate level of detail: business managers see service-level indicators, IT staff see the underlying component metrics, and no role sees data outside their responsibility. Finally, drill-down capability means that each business service indicator links to a second-level view of the contributing technical components, and a third level exposes raw metrics and logs for engineering investigation.

Dashboard Structure

The dashboard is structured across three tiers, each addressing a different audience.

Tier 1 — Executive / Business View (read-only, all authenticated users) presents six status tiles, one per business service, each displaying the current operational state as **Operational**, **Degraded**, or **Unavailable**. A 24-hour availability sparkline accompanies each tile, showing the percentage of time spent in the Operational state over the preceding day. If any P1 or P2 incident is active, a current incident banner is displayed at the top of the view.

Tier 2 — Operations View (IT staff and relevant department managers) provides a per-service component health matrix showing the state, latency, and last check timestamp of each contributing infrastructure component. Key performance indicators are surfaced at this tier: the Order System's request rate and error rate, the Warehouse message queue depth, and database replication lag. WAN link status — MPLS primary or VPN failover — is shown with current bandwidth utilisation.

Tier 3 — Engineering View (IT staff only) exposes raw infrastructure metrics. Individual server dashboards show CPU, memory, disk I/O, network throughput, and process count. Database dashboards cover query throughput, lock contention, replication lag in seconds, and the slow query log. RabbitMQ dashboards present queue depth per queue, consumer lag, and message publish and acknowledge rates. Firewall dashboards show connection table utilisation, blocked connection counts, and bandwidth per VLAN.

Tooling Recommendation

Grafana is recommended as the dashboard platform, consuming metrics from **Prometheus** (time-series metrics) and **Loki** (log aggregation). This stack is open-source, runs on the existing monitoring server in the Management VLAN, and supports role-based access control via LDAP/SAML integration with the IAM. Grafana's "status panel" plugin directly supports the traffic-light service health tiles described in Tier 1.

6.2. Assignment 3 – Status and Performance Monitoring Solution

6.2.1. Scope and Objectives

This monitoring solution addresses status and performance monitoring for all server-class infrastructure components in the LogiFlux environment, across both sites. Derived from the requirements in Chapter 5,

the solution must provide real-time visibility into the operational state of all production servers and detect failures or degraded performance before they impact business services. It must support proactive capacity planning in line with NFR-CAP-01 through NFR-CAP-04, deliver automated alerting within two minutes of a critical failure as required by MR-02, and provide the availability data needed for monthly SLA reporting as required by MR-04.

6.2.2. Architecture

The monitoring architecture follows an **agent-based collection model**: a lightweight metrics agent runs on each monitored host and exposes data to a central Prometheus server in the Management VLAN. This avoids the need to open inbound firewall rules to production servers and reduces the overall attack surface.

For metrics collection, Prometheus uses **node_exporter** on all Linux hosts and **windows_exporter** on all Windows hosts, with additional service-specific exporters deployed per component type as detailed in Table 6.1. Prometheus retains 15 days of high-resolution metrics locally at a 15-second scrape interval; data is then downsampled and forwarded to **Thanos** or **VictoriaMetrics** for the 13-month long-term retention required by MR-06. Grafana, as described in Assignment 2, provides dashboards for all three stakeholder tiers. Alerting is handled by Prometheus **Alertmanager**, which routes alerts by severity: P1 and P2 alerts reach on-call IT staff via PagerDuty, while P3 and informational alerts are published to a Teams or Slack channel. The two-minute detection-to-notification requirement from MR-02 is met by a one-minute scrape interval on critical components combined with a one-minute alert evaluation cycle.

Component	Exporter / Agent	Key Metrics Collected
All Linux servers	node_exporter	CPU (user/sys/iowait), memory (used/cached/available), disk I/O (read/write IOPS, latency), network (bytes in/out, errors), load average, uptime
All Windows servers	windows_exporter	CPU utilisation, memory commit, disk queue length, network interface throughput, Windows event log counters, service state
PostgreSQL	postgres_exporter	Connections (active/idle/waiting), transactions per second, replication lag (seconds), cache hit ratio, deadlocks, longest running query duration
MongoDB	mongodb_exporter	Operations per second (reads/writes/commands), memory resident set, replication oplog window, connections, collection scan counts
RabbitMQ	rabbitmq_exporter	Queue depth per queue, message publish/deliver/ack rates, consumer count per queue, unacknowledged messages, memory and disk alarms
Firewalls (pfSense/OPNsense)	pfsense_exporter / SNMP	Connection table utilisation (%), blocked packets/s, bandwidth per interface, CPU/memory of firewall appliance
WAN link	SNMP on WAN router	Interface bandwidth utilisation (%), packet loss (%), round-trip latency (ms) to Groningen, link state

Table 6.1: Exporters and key metrics per infrastructure component

6.2.3. Alert Thresholds

Alert thresholds are defined at two levels. **P1** alerts require immediate response (on-call engineer notified within 2 minutes). **P2** alerts require same-day response. **P3** alerts are informational and visible in the dashboard only.

Metric	P1 (Critical)	P2 (Warning)	Notes
Server CPU utilisation	>90% for 5 min	>70% for 10 min	Applies to all production nodes
Server memory available	<5% for 5 min	<15% for 10 min	
Disk space remaining	<5%	<15%	Evaluated per-mount
Disk I/O latency	>50 ms avg	>20 ms avg	
Server unreachable	Immediate (node down)	—	Exporter target disappears from Prometheus
PostgreSQL replication lag	>30 s	>10 s	Triggers before standby falls too far behind
PostgreSQL connections	>90% of max	>75% of max	
RabbitMQ queue depth	>10,000 messages	>5,000 messages	Per business-critical queue
WAN link utilisation	>90% sustained	>70% sustained	MPLS or VPN link
WAN packet loss	>5%	>1%	Over a 5-minute window

Table 6.2: Alert thresholds for status and performance monitoring

6.2.4. Groningen Site Monitoring

The monitoring server in Eindhoven's Management VLAN collects metrics from Groningen components over the WAN link. Groningen exporters are scraped by the central Prometheus instance via the MPLS link. A **blackbox exporter** probe is run from Eindhoven to the Groningen firewall's management IP every 30 seconds to provide independent WAN liveness detection.

In the event of a WAN failure, Prometheus marks all Groningen targets as *unreachable* and fires a P1 alert. If a local monitoring agent is desired at the Groningen site, a lightweight **Prometheus remote write agent** (Grafana Agent or Prometheus in agent mode) can buffer metrics locally and forward them when the WAN recovers.

6.2.5. SLA Reporting

Grafana's built-in **SLA/availability reporting** capability generates monthly reports from Prometheus availability data. The report for the Customer Order Portal (NFR-AV-01: 99.9%) is calculated as:

$$\text{Availability} = \frac{\text{Total minutes in month} - \text{Minutes in P1 outage state}}{\text{Total minutes in month}} \times 100\%$$

These reports are exported as PDF and sent automatically to the IT Director and Operations Director at the end of each calendar month (MR-04).

6.3. Assignment 7 – Logging and Forensic Data Collection

6.3.1. Objectives

A centralised logging and forensic readiness solution serves three distinct purposes at LogiFlux:

1. **Operational logging:** Capturing application and system events to support incident diagnosis, troubleshooting and root-cause analysis.
2. **Compliance logging:** Retaining audit trails required by Dutch law (fiscal records: 7 years), GDPR (access logs and data processing records) and internal policy.

3. **Forensic readiness:** Ensuring that in the event of a security incident, sufficient evidence is available in an admissible, tamper-evident form to support investigation and legal proceedings.

6.3.2. Log Sources

The LogiFlux environment generates log data from twelve distinct sources, grouped here by category.

Security and network logs originate from the perimeter firewalls at both Eindhoven and Groningen — capturing connection allow/deny decisions, NAT translations, IDS/IPS alerts, and interface state changes — and from the internal firewall at Eindhoven, which records inter-VLAN traffic decisions and policy violation events. The IAM/SSO server is also a critical security log source, producing authentication events (success and failure), MFA events, session creation and destruction records, and role assignment changes. Windows endpoints at both sites contribute Windows Security Event Log entries covering logon/logoff, privilege use, and process creation (Event IDs 4624, 4625, 4648, 4688, and 4697). The jump host generates the most forensically significant logs: full session recordings capturing keystrokes and timing for all administrative sessions via Teleport or equivalent, alongside command history.

Operational logs come from the load balancer (HTTP access log including method, URI, response code, client IP, and response time, plus backend health check results), the web cluster (application access logs, HTTP error logs, and SSL handshake errors), the RabbitMQ cluster (message publish, consume, ack, and nack events; queue creation and deletion; consumer connect and disconnect), MongoDB (slow query log for queries exceeding 100 ms, authentication events, and replication events), and the monitoring server itself (Prometheus scrape errors and Alertmanager notification delivery and failure records).

Compliance logs are generated by the application clusters — all four produce application error logs and inter-service API call logs, while the Accounting and HR clusters additionally produce user action audit logs attributing each operation to a named identity — and by PostgreSQL, which logs all DDL operations, DML operations on sensitive tables, connection events, authentication failures, and vacuum/checkpoint events.

6.3.3. Centralised Log Architecture

All log sources forward data to a centralised log management platform running on the monitoring server in the Management VLAN. **Fluent Bit** serves as the lightweight forwarder, running as a daemon on all hosts; it collects, parses, and forwards logs over TLS to the central aggregator. Fluent Bit is chosen over Filebeat for its lower resource footprint, which is particularly relevant on the resource-constrained WMS node at Groningen. **Loki** handles log aggregation, storing logs indexed by labels (host, service, VLAN, and site); its label-based indexing model is highly efficient for the LogiFlux log volume and integrates natively with Grafana for unified log and metrics exploration. IT staff query logs using **Grafana**'s Explore interface with LogQL — the same platform used for performance dashboards in Assignment 2 — avoiding the need to deploy a separate UI for logs.

For long-term cold storage (compliance retention beyond 30 days), Loki is configured with an **S3-compatible object storage backend** (on-premises MinIO instance or a compliant cloud bucket). This separates hot operational logs (fast SSD storage, 30-day retention) from cold compliance logs (object storage, 7-year retention for financial audit logs, 36-month retention for security logs per NFR-SEC-05).

6.3.4. Retention Policy

Log Category	Hot (fast)	Cold (object)	Legal/Policy Basis
Security logs (FW, IAM, Jump Host)	30 days	36 months	NFR-SEC-05 / GDPR / incident response
Application audit logs (Accounting)	90 days	7 years	Dutch fiscal law (Belastingdienst)
Application audit logs (HR/Payroll)	90 days	5 years	GDPR / Dutch employment law
Operational logs (web, app servers)	14 days	6 months	Internal policy
RabbitMQ / DB operational logs	14 days	3 months	Internal policy
Jump Host session recordings	90 days	24 months	Security policy / forensic readiness
Windows endpoint event logs	14 days	12 months	Security policy

Table 6.3: Log retention policy by category

6.3.5. Forensic Readiness

Forensic readiness means that the organisation can respond to a security incident or legal request without having to begin evidence collection after the fact. The following measures are implemented:

1. **Tamper-evident log shipping:** Logs are forwarded from source hosts to the central Loki instance via TLS-encrypted, authenticated channels (mTLS between Fluent Bit agents and the Loki ingestor). Once stored in object storage, logs are write-once (object lock / immutability policy) to prevent post-incident modification.
2. **Jump Host session recording:** All administrative sessions through the jump host are recorded using **Teleport** (or equivalent PAM solution), producing a timestamped, replay-capable session log. These recordings are stored in the object store under an immutable retention policy and are immediately available for investigation. This directly satisfies MR-05 and UR-05.
3. **Log integrity:** Each batch of logs shipped to the central aggregator includes an HMAC checksum, allowing verification that no log entries have been deleted or altered in transit or storage.
4. **Chain of custody documentation:** A documented procedure defines who may access log data for forensic purposes, under what conditions, and how evidence is preserved and handed over to external parties (law enforcement, auditors). This procedure is owned by the IT Director.
5. **Forensic collection triggers:** If a P1 security alert is fired, Alertmanager automatically triggers a log snapshot job that archives a 72-hour log window from all sources into a cryptographically signed ZIP archive in isolated storage. This preserves evidence even if an attacker subsequently attempts to delete log data.

6.3.6. Information Flow

The logging information flow is as follows:

1. Sources generate log events (application logs, syslog, Windows Event Log, session recordings).
2. Fluent Bit agents on each host parse, structure (JSON) and enrich events with metadata (hostname, VLAN, site, service name).
3. Events are forwarded over TLS to the Loki ingestor on the Monitoring Server.
4. Loki stores hot logs on local SSD. A background job streams logs older than the hot-tier threshold to the MinIO object store.
5. Grafana provides query access to all tiers via LogQL. Role-based access control limits which log streams each user may query.
6. Alertmanager monitors Loki for pattern-based log alerts (e.g. repeated authentication failures, firewall rule violations) and notifies IT staff via the same alert routing defined in Assignment 3.

6.3.7. GDPR Considerations

Centralised logging inevitably involves processing personal data (usernames, IP addresses, potentially employee activity records). Log data is pseudonymised where possible, with internal user identifiers replacing full names in non-audit logs. Access to logs containing personal data — HR audit logs and employee endpoint logs — is restricted to the IT Director and HR Manager through Grafana's RBAC policy. A **Data Processing Register** entry is maintained for the logging system, documenting data categories, retention periods, and access controls as required by GDPR Article 30. All logs are stored within the EU, on-premises in the Netherlands, with any cloud object storage restricted to an EU region.